

网盘攻防项目任务说明一

这是一个涉及Web开发和Web安全两个方面的课外工程实践项目，主要面向大一阶段具有程序设计基础且学有余力的同学。该项目以实际工程和需求驱动，我们会定期在群里给出每一步的任务说明，提供必要的学习资料并进行答疑。整个项目一共分为三大阶段：

- Web项目开发阶段：开发出一个包含用户注册、登录及文件上传、下载的网盘系统。
- 安全攻防阶段：以网盘系统为原型，组间合作完成攻防。
- 系统完善阶段：继续提升系统安全性、功能。

在每个阶段中，又会拆分成若干个子任务，**每个子任务的预期完成时间为一周至两周，以组为单位提交完成的成果**。我们也会以周为单位根据大家的完成情况和完成过程中产生的疑问有针对性地进行答疑。

在三大阶段完成后，最终以**组为单位进行答辩**，答辩时我们会随机让每个小组现场演示某个安全漏洞的产生及修复过程，小组**每个成员**需要阐述自己完成的功能或进行的攻防加固，以及背后的原理并回答老师的提问。

我们鼓励大家自学，能发现问题并提出问题、作出假设、自主搜集资料、并能动手实践验证和应用的“系统级思维”是一种非常重要的能力，大家今后进入工作岗位后会逐渐发现，这种能力甚至比在学校中通过课程系统学习到的某个领域的具体知识更为重要！或许若干年以后，你会忘记很多你在课程上学到的具体知识，当然也包括你在网盘攻防项目中学到的安全攻防和开发技能，但这种“系统级思维”将能让你足够快地进入一个全新的领域。

接下来是给大家的第一次任务以及一些建议。

一、搭建开发环境

1-1. 安装并配置虚拟机（推荐，非必须，但可能影响分数）

虽然这不是必须的，但我们还是强烈推荐大家将项目的开发环境和运行环境搭建在虚拟机中。虚拟机在现有的操作系统（宿主机）之上，利用软件模拟（也包括硬件的虚拟化功能）出一套计算机硬件，并允许我们在其中安装与宿主机完全不同的操作系统。部分功能强大的虚拟机还提供了快照功能，允许我们方便地对虚拟机当前状态进行保存，并在今后需要的时候快捷地恢复到当前的状态。

在本项目中引入虚拟机有以下几个好处：

1. 避免因宿主机上各类因素导致开发环境被破坏，需要重新安装。曾有同学因为安装其他程序、宿主机中毒或卡顿，导致开发环境被破坏或需要重装系统，其后需要经历漫长的开发环境重新安装和配置的过程。
2. 在攻防阶段，针对系统的攻击会不可避免地对运行Web服务的机器及系统环境造成一定的破坏，包括但不限于数据丢失、病毒/后门/木马的植入、页面被篡改等等，如果将Web服务直接部署在你的电脑上，环境和数据的恢复将需要耗费极大的精力，甚至埋下安全隐患。
3. 在答辩演示阶段，我们会随机让每个小组现场演示某个安全漏洞的产生及修复过程，利用虚拟机的快照及恢复功能，可以快速而容易地切换到存在安全隐患的版本，并进行修复。当然，你也可以选择不使用虚拟机，通过git等版本控制软件或者现场手工修改代码实现漏洞的复现与修复，但需要注意的是，能否在答辩中快速复现漏洞，是答辩环节中评分的一个维度。
4. 虚拟机可以比较方便地进行拷贝和分发，并在组内成员间共享。

目前，主流的虚拟机有VirtualBox和VMWare两款，他们都支持快照功能。

- VirtualBox是一款开源免费的虚拟机，下载页面：<https://www.virtualbox.org/wiki/Downloads>

- VMWare WorkStation是一款功能强大并提供试用的虚拟机，下载页面：
<https://www.vmware.com/cn/products/workstation-pro/workstation-pro-evaluation.html>

虚拟机安装Windows时，所需的镜像可以到<https://msdn.itellyou.cn/> 上下载，可以使用迅雷等工具进行下载。

大家可以选择一款并在其中安装64位的Windows7或Windows10操作系统，在网上搜索很容易找到安装系统的教程。不知道如何使用虚拟机安装系统的同学可以参考以下视频，以VirtualBox安装Windows操作系统为例：

[webpage](#)

本项目建议统一使用虚拟机安装Windows开发环境，安装Windows 7 x64版本或Windows 10 x64版本的虚拟机。

1-2. 安装并配置JDK

由于我们接下来使用Java语言开发项目，因此要安装JDK，JDK包含了Java开发所需的编译环境、库以及运行环境。截至目前，最新的JDK下载地址为<https://www.oracle.com/java/technologies/downloads/>

如果你打算使用Servlet+JDBC的方式完成项目的开发（这也是在初学阶段我们推荐大家使用的方式），则可以直接安装最新的JDK版本。如果你希望使用各种JavaWeb框架，则需要根据对应JavaWeb框架的适配情况选择对应的JDK版本。

下载安装后，需要将JDK安装路径配置为JAVA_HOME的环境变量，并将%JAVA_HOME%\bin路径增加到Path环境变量中。大家可以自行在网上搜索JDK安装教程，也可以参考以下视频（<https://www.bilibili.com/video/BV1NL4y1u7C3>），该视频中配置的JDK版本为JDK14，JDK后续版本的配置与其没有区别。

以下是JDK8的配置过程：<https://www.bilibili.com/video/BV1Kb411W75N?p=30>

以下是JDK17的配置过程：<https://www.bilibili.com/video/BV1NL4y1u7C3?zw>

[webpage](#)

1-3. 安装并配置Tomcat

Tomcat是实现了Servlet规范的Web容器。我们的JavaWeb将借助Tomcat提供的能力来接收前端发往后台的请求并进行答复（数据交互）。Tomcat官网下载地址为：<https://tomcat.apache.org/download-90.cgi> 对于打算使用Servlet+JDBC方式进行开发的同学，推荐大家使用Tomcat 9版本。如果你要使用其他框架，需要遵循框架当前匹配的Tomcat版本。我们提供了Tomcat 9和Tomcat 8.5两个版本，大家可以根据实际情况选择安装一个。

Tomcat配置比较简单，解压后设置环境变量CATALINA_HOME并指向其解压位置即可。可以参考之前给大家推荐过的JavaWeb视频中的Tomcat安装：<https://www.bilibili.com/video/BV1AS4y177xJ?p=19>

1-4. 安装并配置IDE

为保证开发的高效，我们将安装并配置集成开发环境。目前JavaWeb开发领域，使用最广泛的IDE为IDEA及eclipse。

- eclipse是开源免费的老牌IDE，<https://www.eclipse.org/downloads/packages/> 注意选择“Eclipse IDE for Enterprise Java and Web Developers”
- IDEA是一款针对Java编程的商用IDE，提供30天的免费试用期：
<https://www.jetbrains.com/idea/download/#section=windows> 针对在校学生，可以通过提供学信网的学籍验证报告后获得授权并免费使用。

IDEA相对而言易用性更好一些，但需要验证学籍信息以获取授权，我们鼓励有能力获取授权的同学使用IDEA。如果不希望在授权获取上耗费时间，也可以使用开源免费的eclipse。我们为大家提供了截至目前最新的支持JavaWeb项目开发的eclipse版本压缩包。

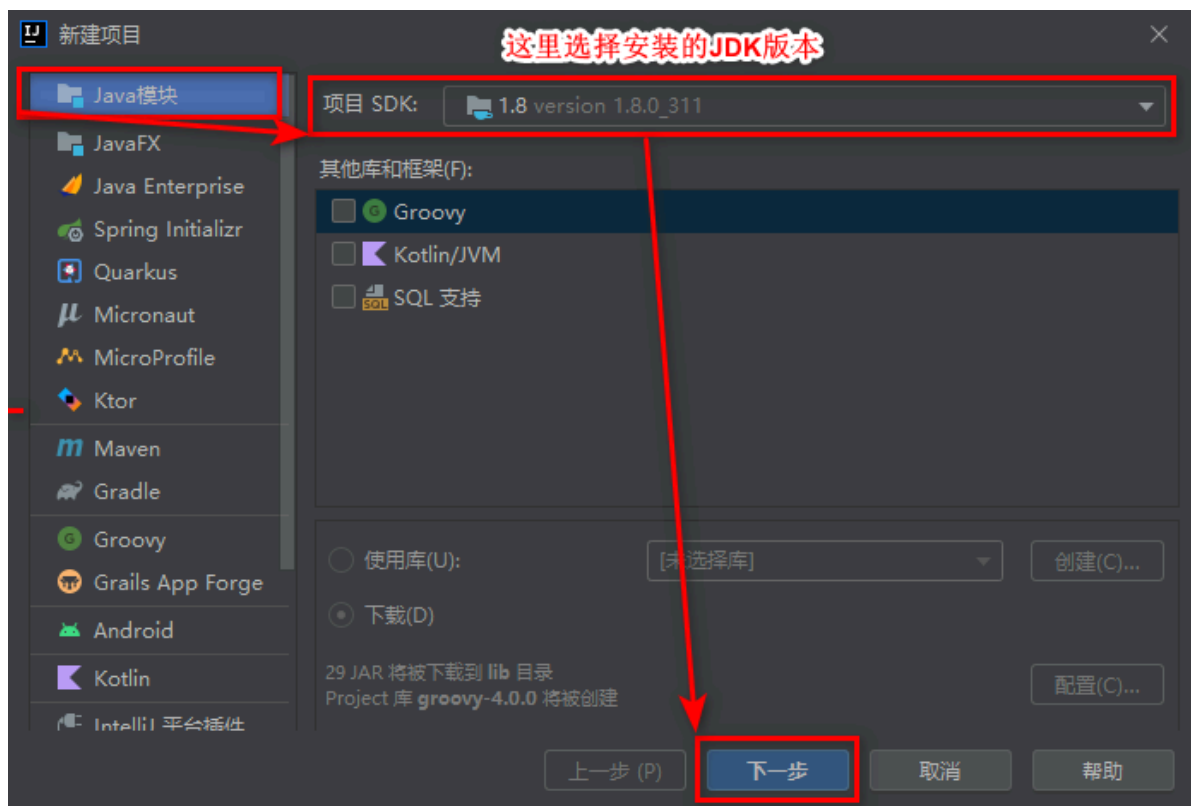
针对eclipse安装之后如何快速修改字体、整合JDK和Tomcat，可以参考这篇CSDN文章：

<https://blog.csdn.net/LPWSTR/article/details/78303892>，更多关于eclipse的使用，也可以参考B站教程（这份教程比较全面，大家可以根据自己想了解的章节选择性地观看）

<https://www.bilibili.com/video/BV1su411q7Yu>

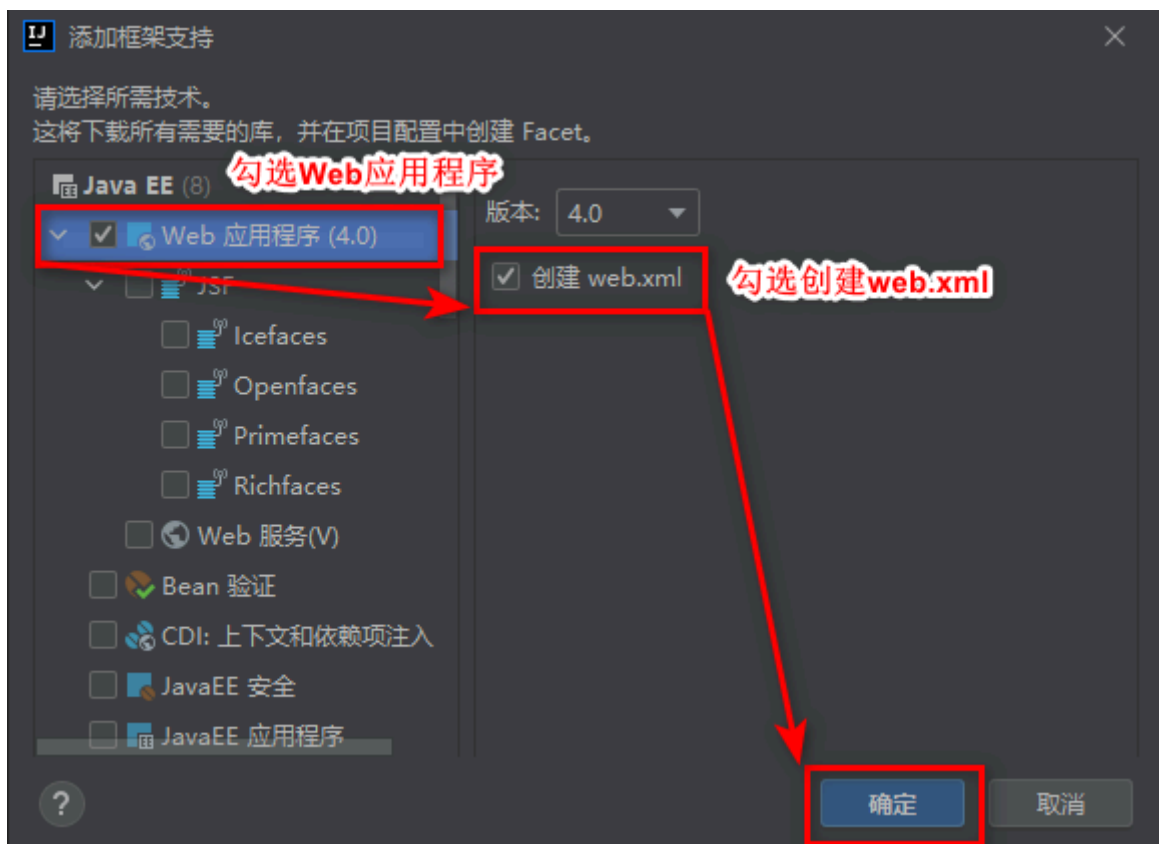
针对IDEA创建JavaWeb工程及整合tomcat，可以参考之前推荐过的B站JavaWeb2022版教程中对应的章节：<https://www.bilibili.com/video/BV1AS4y177xj?p=20> 如果你使用的是较新版本的IDEA，创建JavaWeb项目的方式与视频中略有区别：

1. 首先创建普通Java工程



2. 在创建的Java工程上右键——属性——





二、学习Servlet并编写注册及登录逻辑（不带数据库）

2-0. 学习基本的前端开发技能（推荐，非必须，但可能影响分数）

前端开发并非我们项目的主线，本项目也并不对前端界面的美观程度提出很高的要求，但我们还是希望你能掌握最基本的HTML+JS+CSS技能，因为攻防阶段的XSS攻击就需要相关知识。

基于学习效率的考虑，我们为大家提供了一个登录和注册界面的前端Demo，在群文件中的Register&LoginDemo.7z，大家可以选择在此Demo上继续进行开发和完善。要使用该Demo仍然需要你具有一定的前端基础。建议大家在此Demo的基础上进行进一步的开发、修改和完善，直接使用此Demo可能会影响分数。

关于前端部分，建议大家学习之前推荐的JavaWeb2022视频的2-17课：

<https://www.bilibili.com/video/BV1AS4y177xj?p=2>

2-1. 学习Servlet开发

如果你之前没有学习过Web开发，我们建议你直接使用Servlet，等到熟悉了Servlet之后再学习后续框架。Servlet是一套JavaWeb协议规范（定义好的接口），Tomcat容器遵照这种规范实现了一套http服务框架，使得我们只需要按照Servlet接口规范进行简单的继承和配置，即可借助Request及Response专注于自身业务的开发。通常而言，遵循Servlet规范进行Web开发需要遵循以下步骤：

1. 继承HttpServlet，实现doPost和doGet方法
2. 使用注解或配置web.xml，建立URL到Servlet类的映射关系

建议大家学习之前推荐的JavaWeb2022视频的21-26课，

<https://www.bilibili.com/video/BV1AS4y177xj?p=21> 掌握如下内容：

- 浏览器与后台的http协议交互过程
- 创建JavaWeb工程与Servlet对应jar包的引入
- 如何编写Servlet响应get/post请求（我们统一使用post方式）

- 如何注册Servlet并指定其路径（例如将localhost:8080/register关联到RegisterServlet）
- 如何获取post请求传递的参数
- 如何运行JavaWeb工程

由于我们还没有引入数据库，因此在这个阶段，你可以在Servlet类中直接println接收到的信息。待我们后续引入了数据库之后，再完成真实的逻辑。以下是针对登录操作在本阶段的一个Demo：

```
@WebServlet("/login")
public class Login extends HttpServlet {
    @Override
    protected void doPost(HttpServletRequest req, HttpServletResponse resp)
    throws ServletException, IOException {
        String email = req.getParameter("email");
        String password = req.getParameter("password");
        // 由于暂时没有引入数据库，直接println即可
        System.out.println(email + ":" + password);
    }
}
```

需要注意的是，在本项目中**直接使用现成的JavaWeb框架并不额外加分**，这里指的JavaWeb框架主要是以下几类：

- DI/AOP类框架，如Spring以及Spring全家桶等
- MVC框架，如SpringMVC及Struts2等
- ORM框架，如Hibernate及MyBatis等

我们鼓励大家在了解Servlet+JDBC开发方式之后，自己尝试实现DI、MVC及ORM框架的功能，自己实现这些功能在项目答辩时会加分。

2-2. 补充Java面向对象编程

在Servlet开发过程中，我们接触到了Java的类以及继承相关的语法，对于初次接触Java的同学可能比较懵。这时候，可以对照Servlet视频中使用到的继承等知识点，快速看看廖雪峰老师的Java教程面向对象部分：<https://www.liaoxuefeng.com/wiki/1252599548343744/1260451488854880>

三、预习

以下是下个任务中将会出现的部分知识，学有余力的同学在完成了上述任务后可以提前学习了解下。

3-1. SQL基本语句及JDBC

在本任务中，我们无论是register还是login都没有进行与数据库相关的交互，因此接下来，大家要熟悉下数据库相关的内容。

- MySQL的安装与使用：<https://www.bilibili.com/video/BV1iq4y1u7vj?p=7>（7-8）
- 基本SQL语句的快速入门：<https://www.bilibili.com/video/BV1yw4m1S7Be/>
- 使用Java操作数据库（JDBC）：
<https://www.liaoxuefeng.com/wiki/1252599548343744/1305152088703009>

3-2. Git及Gitee的使用（推荐）

由于每个项目组都涉及到多人协同开发，并且开发过程中可能涉及到版本的迭代与回退，我们强烈建议大家使用Git来进行版本控制。Git的下载、安装和基本使用请参考廖雪峰老师的教程：

<https://www.liaoxuefeng.com/wiki/896043488029600>

另外B站上有个18分钟的Git入门教程，可以供大家参考：

<https://www.bilibili.com/video/BV1i44y1e7hv>